

- **Expediente N.º: EXP202412881**

RESOLUCIÓN DE TERMINACIÓN DEL PROCEDIMIENTO POR RECONOCIMIENTO DE RESPONSABILIDAD Y PAGO VOLUNTARIO

Del procedimiento instruido por la Agencia Española de Protección de Datos y en base a los siguientes

ANTECEDENTES

PRIMERO: Con fecha 3 de febrero de 2025, la Presidencia de la Agencia Española de Protección de Datos acordó iniciar procedimiento sancionador a **IBERMUTUA, MUTUA COLABORADORA CON LA SEGURIDAD SOCIAL NUM.274** (en adelante, **IBERMUTUA**), mediante el acuerdo que se transcribe:

<<

Expediente N.º: EXP202412881

ACUERDO DE INICIO DE PROCEDIMIENTO SANCIONADOR

De las actuaciones practicadas por la Agencia Española de Protección de Datos y en base a los siguientes

HECHOS

PRIMERO: Con fechas 01/08/2024, 09/08/2024, de nuevo 09/08/2024, 21/08/2024, 22/08/2024, 26/08/2024 y 06/09/2024 se han interpuesto sendas reclamaciones, en relación con los mismos hechos, ante la Agencia Española de Protección de Datos por una posible infracción imputable a **IBERMUTUA MUTUA COLABORADORA CON LA SEGURIDAD SOCIAL Nº 274** con NIF **G81939217** (en adelante, **IBERMUTUA**).

Los reclamantes manifiestan haber recibido una comunicación remitida por el Delegado de Protección de Datos (DPD) de **IBERMUTUA** en la que se les informa de que debido a un error informático se habían remitido datos personales, que incluían datos sobre salud, a diferentes empresas y entidades, con las que **IBERMUTUA** se había puesto en contacto para que fueran eliminados. Junto a las reclamaciones aportan los escritos remitidos.

SEGUNDO: De conformidad con el artículo 65.4 de la Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y garantía de los derechos digitales (en adelante LOPDGDD), se dio traslado de dicha reclamación a **IBERMUTUA**, para que procediese a su análisis e informase a esta Agencia en el plazo de un mes, de las acciones llevadas a cabo para adecuarse a los requisitos previstos en la normativa de protección de datos.

La notificación del traslado de la reclamación, que se practicó conforme a las normas establecidas en la Ley 39/2015, de 1 de octubre, del Procedimiento Administrativo

Común de las Administraciones Públicas (en adelante, LPACAP), fue realizada en fecha 01/10/2024 como consta en el acuse de recibo que obra en el expediente.

Con fecha 04/11/2024 se recibe en esta Agencia escrito de respuesta, indicando lo siguiente:

Que **Ibermutua Digital Empresas/Asesorías** es una plataforma en línea dirigida a empresas que colaboran en la gestión de trámites ante IBERMUTUA (Mutua Colaboradora con la Seguridad Social). Su finalidad principal es digitalizar y facilitar la gestión de trámites y consultas relacionadas con prestaciones económicas a cargo de IBERMUTUA, de las que son beneficiarias personas trabajadoras en empresas usuarias de la plataforma.

El 15/07/2024, una empresa usuaria de la plataforma informa a IBERMUTUA de que en un correo electrónico de notificación semanal con la situación de bajas laborales de sus empleados, se acompañan archivos adjuntos con datos relativos a personas ajenas a su empresa. A raíz de esa comunicación se detecta un error humano en la programación en el envío de archivos adjuntos en emails remitidos desde la plataforma, en los que se han ido concatenando y adjuntando ficheros de Excel con información de empleados de otras empresas y entidades.

En concreto, se añadió un comentario a una línea de código que hacía que se reseteara el envío adjunto del Excel en cada nueva notificación. La introducción de un comentario hace que la línea de código no se ejecute y, en consecuencia, en cada envío se adicionan los anteriores generados en la misma emisión del día y que iban dirigidos a otros destinatarios.

El incidente afecta a los datos 3.395 personas, cuyos datos fueron enviados a un total de 354 destinatarios de empresas y asesorías colaboradoras de IBERMUTUA. La información incluía los siguientes datos personales (en la respuesta se detallan el número de personas de las que se filtró cada uno de estos datos):

- Nombre y apellidos
- NIF/NIE
- Número de afiliación a la Seguridad Social (NAF)
- Edad
- Tipo de contingencia (en relación con su prestación económica de la Seguridad Social)
- Si se trataba de un proceso con baja o sin baja laboral
- Fecha de la baja
- Fecha del alta laboral
- Número de días de baja laboral hasta el momento de la notificación
- Empresa del trabajador/a
- Causa del alta
- Días previstos de baja laboral
- Base Reguladora para el cálculo de la prestación económica
- Coste total o parcial del proceso
- Coste aproximado de cotización
- CNO (Código Nacional de Ocupación) del trabajador/a
- Si tiene o no carencia para tener derecho a la prestación económica

- Si se trata o no de un accidente de trabajo in itinere
- Si se trata o no de un accidente de tráfico
- Sexo (H o M)

IBERMUTUA afirma que tras la detección de la brecha realizó las siguientes acciones:

- Medidas técnicas de carácter inmediato:
 - o Corrección del error en el programa y establecimiento de una serie de pruebas exhaustivas para comprobar el correcto funcionamiento de cualquier cambio futuro.
 - o Restricción de archivos adjuntos para que el sistema no permita el envío de múltiples adjuntos en un solo correo.
 - o Verificación del ID del archivo adjunto con el destinatario correspondiente.
 - o Pruebas previas al envío de remesas de emails con una muestra.
- Medidas operacionales de carácter inmediato: contactó con las 354 entidades receptoras por error de la información para que procedieran a su eliminación. IBERMUTUA hizo un seguimiento de la confirmación por parte de dichas entidades de la eliminación de sus datos, finalizando ese proceso el 06/09/2024.
- Se documentó y notificó la brecha a la AEPD el 17/07/2024.
- Se informó por correo electrónico o postal a las personas afectadas.

Asimismo, IBERMUTUA informa de las medidas de seguridad de los tratamientos adoptadas con anterioridad al incidente detallando:

- Medidas de seguridad (arquitectura, tecnologías utilizadas, seguridad y trazabilidad)
- Medidas organizativas
 - o Declaración de privacidad en materia de datos personales
 - o Procedimiento de obligaciones del personal en seguridad de la información y protección de datos, de obligado cumplimiento para todo el personal.
- Medidas operacionales
 - o Medidas formativas para su plantilla, en particular en relación con protección de datos
- Análisis de riesgos, aportando documentación acreditativa de los análisis de riesgos realizados, en particular, en relación con el tratamiento “prestaciones económicas” y con el tratamiento “relación con las empresas mutualistas”, en los que no se evidenció un riesgo alto para los derechos y libertades de los interesados.
- Asimismo, afirma que en julio de 2024 se dio comienzo a una auditoría externa en materia de protección de datos que incluía la realización de los análisis de

riesgos y las evaluaciones de impacto de ocho de los tratamientos de Ibermutua, entre ellos los afectados en el presente caso. No obstante, no consta la fecha de dicha auditoría ni IBERMUTUA adjunta documentación sobre la misma.

Por último, IBERMUTUA informa de las medidas que piensa adoptar para que no se vuelva a producir un incidente similar en el futuro:

“Medidas técnicas.

Objetivo

Implementar un sistema en AWS que gestione de manera segura la generación de enlaces de descarga de documentos. El nuevo sistema se enfocará en garantizar que:

- Los enlaces generados estén protegidos mediante niveles de seguridad y accesos restringidos.*
- Se minimice la posibilidad de errores de cruce de datos a través de controles adicionales y auditorías.*
- Se mantenga un registro completo de accesos y acciones realizadas sobre los documentos.*

Componentes.

El nuevo sistema constará de los siguientes componentes clave:

- API Gateway: Punto de entrada para las solicitudes HTTP (subida y descarga de documentos).*
- AWS Lambda: Funciones encargadas de la lógica de negocio:*
 - ✓ Subida de documentos: Recibe el documento, lo almacena en S3, y guarda los metadatos (hash, niveles de seguridad, caducidad, etc.).*
 - ✓ Descarga de documentos: Verifica el hash, la caducidad y la seguridad del documento, y en caso de ser válido, genera la respuesta de descarga*
- Amazon S3: Almacenamiento seguro de los documentos.*
- CloudWatch: Registro de accesos, control de errores y auditoría en tiempo real.*
- Sesión de Auditoría: Almacenar información sobre las IPs que acceden a los documentos, cuándo lo hacen, y la validez de los accesos (incluyendo intentos fallidos).*

Funciones Clave.

- Seguridad en la descarga: Se requerirá un nivel de seguridad adecuado para acceder al documento, como un PIN en función de la sensibilidad del documento.*
- Gestión de errores: En caso de error en la descarga, el sistema devolverá un mensaje de error detallado, con un registro del error en CloudWatch para su revisión.*
- Caducidad automática: Los documentos se eliminarán de S3 pasado el tiempo de caducidad, minimizando el riesgo de exposición a largo plazo.*

Medidas operativas.

- *Se ha registrado el incidente ocurrido con número de referencia DAU-136933 en la plataforma de Ibermutua destinada al efecto Jira-Service Desk.*
- *Una vez producida la brecha de seguridad y materializado el riesgo de errores técnicos y humanos, afectando a la dimensión de la confidencialidad, se ha llevado a cabo la revisión de los análisis de riesgos en materia de protección de datos tanto del tratamiento de 'Prestaciones Económicas' como el denominado 'Relación con las Empresas Mutualistas'."*

A su respuesta adjunta la siguiente documentación:

- Comunicaciones realizadas a la entidades receptoras por error de la información, así como sus confirmaciones de haber eliminado los datos.
- Comunicaciones a las personas afectadas.
- Guía de usuario de **Ibermutua Digital Empresas / Asesorías**.
- Documentación sobre la comunicación de la brecha a la AEPD.
- Manual interno de procedimientos en materia de seguridad de la información y privacidad.
- Información divulgativa sobre seguridad y protección de datos para su personal
- Análisis de riesgos y evaluaciones de necesidad y proporcionalidad de las operaciones de tratamiento objeto de este procedimiento.
- Formulario de valoración ENS del sistema de información de IBERMUTUA.
- Informes de evaluación de impacto en la protección de datos de los tratamientos objeto de este procedimiento.
- Registro de actividades de tratamiento de la empresa.

TERCERO: Con fecha 29/11/2024, de conformidad con el artículo 65 de la LOPDGDD, se admitieron a trámite las reclamaciones mencionadas. Con fecha 21/10/2024 se recibió una nueva reclamación sobre los mismos hechos que se admitió a trámite el 10/12/2024.

CUARTO: De acuerdo con el informe recogido de la herramienta AXESOR, la entidad IBERMUTUA es una empresa constituida en el año 1992, y con un volumen de negocios de (...) euros en el año 2023.

FUNDAMENTOS DE DERECHO

I

Competencia

De acuerdo con los poderes que el artículo 58.2 del Reglamento (UE) 2016/679 (Reglamento General de Protección de Datos, en adelante RGPD), otorga a cada autoridad de control y según lo establecido en los artículos 47, 48.1, 64.2 y 68.1 de la Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y garantía de los derechos digitales (en adelante, LOPDGDD), es competente para iniciar y resolver este procedimiento la Presidencia de la Agencia Española de Protección de Datos.

II Procedimiento

Asimismo, el artículo 63.2 de la LOPDGDD determina que: *“Los procedimientos tramitados por la Agencia Española de Protección de Datos se regirán por lo dispuesto en el Reglamento (UE) 2016/679, en la presente ley orgánica, por las disposiciones reglamentarias dictadas en su desarrollo y, en cuanto no las contradigan, con carácter subsidiario, por las normas generales sobre los procedimientos administrativos”.*

De acuerdo con el artículo 64 de la LOPDGDD, y teniendo en cuenta las características de la presunta infracción cometida, se inicia un procedimiento sancionador.

El procedimiento tendrá una duración máxima de doce meses a contar desde la fecha del acuerdo de inicio. Transcurrido ese plazo se producirá su caducidad y, en consecuencia, el archivo de actuaciones, de conformidad con lo establecido en el artículo 64 de la LOPDGDD.

Si en el plazo estipulado no efectuara alegaciones a este acuerdo de inicio, el mismo podrá ser considerado propuesta de resolución, según lo establecido en el artículo 64.2.f) de la Ley 39/2015, de 1 de octubre, del Procedimiento Administrativo Común de las Administraciones Públicas (en lo sucesivo, LPACAP).

III Cuestiones previas

En el presente caso, de acuerdo con lo establecido en el artículo 4.1 y 4.2 del RGPD, consta la realización de un tratamiento de datos personales, toda vez que IBERMUTUA lleva a cabo, entre otras operaciones, la recogida, registro, conservación, estructuración y comunicación a través de la plataforma mencionada de datos de personas físicas. En concreto, en lo que afecta a este procedimiento: nombre y apellidos, NIF, NIE, número de afiliación a la Seguridad Social (NAF), edad, sexo, datos relativos a prestaciones económicas de la Seguridad Social y a las contingencias que dan lugar a las mismas (motivo y fechas de bajas y altas laborales, accidentes, etc.) y datos sobre relaciones laborales (empleador, ocupación, bases de cotización, etc.)

La operativa en el marco del cual se realiza el tratamiento es la siguiente: IBERMUTUA es una mutua colaboradora de la Seguridad Social y, como tal, gestiona determinadas prestaciones (accidentes de trabajo, enfermedad profesional, etc.) Empresas y asesorías (gestorías, despachos...) pueden asociarse con IBERMUTUA para que ésta gestione las prestaciones de las que son beneficiarios sus trabajadores (o trabajadores de sus clientes, en el caso de asesorías). Para la gestión de dichas prestaciones, IBERMUTUA recoge y trata datos personales de dichos trabajadores.

Entre los servicios que ofrece a empresas y asesorías asociadas, IBERMUTUA cuenta con una plataforma digital, llamada ***Ibermutua Digital***. Esta plataforma, entre otras funcionalidades, ofrece a sus asociados información sobre el estado de las prestaciones de sus trabajadores, que incluyen los datos anteriormente citados. A esa información se puede acceder en diferentes formatos, uno de los cuales, objeto de

este procedimiento, es el envío a las empresas y asesorías de un correo electrónico semanal, configurable, que contiene un fichero Excel con la información (y los datos personales antes citados) correspondiente a los trabajadores de la empresa o asesoría asociada.

IBERMUTUA realiza esta actividad en su condición de responsable del tratamiento, dado que es quien determina los fines y medios de tal actividad, en virtud del artículo 4.7 del RGPD, ya que es quien determina los fines y medios del tratamiento.

IV

Obligación incumplida. Integridad y confidencialidad

La letra f) del artículo 5.1 del RGPD propugna:

"1. Los datos personales serán:

(...)

f) tratados de tal manera que se garantice una seguridad adecuada de los datos personales, incluida la protección contra el tratamiento no autorizado o ilícito y contra su pérdida, destrucción o daño accidental, mediante la aplicación de medidas técnicas u organizativas apropiadas («integridad y confidencialidad»)."

En el presente caso, ha quedado acreditado que el día 15/07/2024 IBERMUTUA tiene constancia de que se ha producido una brecha de datos personales que la propia empresa notifica el 17/07/2024 a esta Agencia. La brecha consiste en el envío a distintas entidades colaboradoras de IBERMUTUA de datos de personas que no pertenecían a dichas empresas y que, por tanto, no estaban legitimadas para conocer.

De la documentación aportada por la empresa se concluye que dicha brecha fue producida por un error en la programación del envío de notificaciones a esas entidades a través de la plataforma de IBERMUTUA, **Ibermutua Digital Empresas/Asesorías**.

A partir de las reclamaciones presentadas por las personas cuyos datos se vieron afectados por dicha brecha, corresponde analizar si en las operaciones de tratamiento en el que ésta se produjo, IBERMUTUA garantizó una seguridad adecuada de los datos mediante la aplicación de medidas técnicas u organizativas apropiadas. Esto es, si IBERMUTUA, como responsable del tratamiento, cumplió con las obligaciones que establece el RGPD a los responsables de tratamiento y, en particular, con el principio de integridad y confidencialidad que establece el artículo 5.1 del RGPD.

A este respecto, en su respuesta IBERMUTUA detalla una serie de medidas adoptadas por la empresa, mencionadas anteriormente, que son tanto de carácter técnico como organizativo, incluida la realización de evaluaciones de riesgos.

Procede analizar las medidas específicas adoptadas en lo que afecta a este caso concreto. IBERMUTUA manifiesta que la brecha se debe a un error de programación en envío de correo electrónico que realiza a través de la plataforma **Ibermutua Digital Empresas/Asesorías**, y que tienen como destinatarios a diferentes entidades colaboradoras de IBERMUTUA (empresas y gestorías). En concreto, los usuarios de dicha plataforma pueden optar recibir comunicaciones por correo electrónico con

información sobre prestaciones económicas de personas trabajadoras correspondientes a su entidad y pueden configurar determinados parámetros.

De acuerdo con IBERMUTUA, hay un proceso programado (denominado “notificador”) en el que se prepara un fichero Excel con la información y la periodicidad que los usuarios ha configurado. Una vez preparado el fichero, se envía un correo a la dirección que el usuario ha configurado, en la que se adjunta ese fichero Excel.

En este proceso, de acuerdo con la respuesta de IBERMUTUA:

“El incidente se ha producido a raíz de una modificación en el notificador. Por un error humano se comentó una línea de código (al comentarse una línea de código, esta no se ejecuta) que es la que hacía que se reseteara el envío adjunto del Excel en cada nueva notificación. De esta forma, en esta ocasión, en cada envío se comunicó el correspondiente archivo de Excel, y se adicionaron los anteriores que se habían generado en la misma emisión de ese día.”

En su escrito de respuesta, IBERMUTUA señala que con carácter inmediato fueron adoptadas varias medidas técnicas, entre las que cita las siguientes:

- “• Corrección del problema. La primera acción fue corregir el error y establecer una serie de pruebas exhaustivas para comprobar el correcto funcionamiento de cualquier cambio futuro, sin importar su magnitud.*
- Restricción de archivos adjuntos. Se implementó una restricción para que el sistema no permita el envío de múltiples adjuntos en un solo correo. Si se detecta tal situación, el proceso de envío se detiene automáticamente.*
- Verificación del ID del archivo adjunto. Se procede a verificar que el ID del fichero adjunto corresponde al usuario destinatario antes de proceder con el envío. Si hay discrepancias, el envío se aborta.*
- Pruebas previas al envío de remesas de emails. Antes de realizar envíos de emails, se llevan a cabo pruebas con una muestra de 20 casos para asegurarse de que todo esté en orden. Si se detecta algún problema, el envío se cancela.”*

En relación con dichas medidas, cabe considerar que se trataría de medidas de seguridad básicas en relación con un procedimiento de la envergadura y características del presente caso, dado que, como señala IBERMUTUA, el servicio de notificaciones en el marco del cuál se produce la brecha implica el envío de una cantidad muy elevada de envíos (una media de 250.000 envíos mensuales), que incluyen datos personales (algunos de ellos correspondientes a categorías especiales, como datos sobre salud) relativos a un número muy elevado de interesados.

Puede considerarse que hubiera resultado razonable contar con algún mecanismo de control en dichos envíos para prevenir o detectar errores en la configuración o en el procedimiento de envío. En este sentido, IBERMUTUA cita en su respuesta medidas básicas como la restricción del número de archivos adjuntos, una verificación de la correspondencia entre los datos incluidos y la pertenencia de las personas a la empresa destinataria o la realización de pruebas con una muestra.

Por tanto, de conformidad con las evidencias de las que se dispone en este momento de acuerdo de inicio de procedimiento sancionador, se considera que los hechos conocidos podrían ser constitutivos de una infracción, imputable a IBERMUTUA, por vulneración del artículo transcrito anteriormente.

V

Tipificación de la infracción del artículo 5.1.f) del RGPD y calificación a efectos de prescripción

El artículo 83.5 del RGPD tipifica como infracción administrativa la vulneración del artículo siguiente, que se sancionará, de acuerdo con el apartado 2, con multas administrativas de 20.000.000 EUR como máximo o, tratándose de una empresa, de una cuantía equivalente al 4 % como máximo del volumen de negocio total anual global del ejercicio financiero anterior, optándose por la de mayor cuantía:

"a) los principios básicos para el tratamiento, incluidas las condiciones para el consentimiento a tenor de los artículos 5, 6, 7 y 9;"

Por su parte, la LOPDGDD en su artículo 71, Infracciones, señala que:

"Constituyen infracciones los actos y conductas a las que se refieren los apartados 4, 5 y 6 del artículo 83 del Reglamento (UE) 2016/679, así como las que resulten contrarias a la presente ley orgánica".

A los solos efectos del plazo de prescripción, el artículo 72.1 de la LOPDGDD establece lo siguiente:

"En función de lo que establece el artículo 83.5 del Reglamento (UE) 2016/679 se consideran muy graves y prescribirán a los tres años las infracciones que supongan una vulneración sustancial de los artículos mencionados en aquel y, en particular, las siguientes:

a) El tratamiento de datos personales vulnerando los principios y garantías establecidos en el artículo 5 del Reglamento (UE) 2016/679."

VI

Propuesta de sanción

A fin de determinar la multa administrativa a imponer se han de observar las previsiones de los artículos 83.1 y 83.2 del RGPD, preceptos que señalan:

"1. Cada autoridad de control garantizará que la imposición de las multas administrativas con arreglo al presente artículo por las infracciones del presente Reglamento indicadas en los apartados 4, 9 y 6 sean en cada caso individual efectivas, proporcionadas y disuasorias.

2. Las multas administrativas se impondrán, en función de las circunstancias de cada caso individual, a título adicional o sustitutivo de las medidas contempladas en el artículo 58, apartado 2, letras a) a h) y j). Al decidir la imposición de una multa administrativa y su cuantía en cada caso individual se tendrá debidamente en cuenta:

- a) la naturaleza, gravedad y duración de la infracción, teniendo en cuenta la naturaleza, alcance o propósito de la operación de tratamiento de que se trate así como el número de interesados afectados y el nivel de los daños y perjuicios que hayan sufrido;
- b) la intencionalidad o negligencia en la infracción;
- c) cualquier medida tomada por el responsable o encargado del tratamiento para paliar los daños y perjuicios sufridos por los interesados;
- d) el grado de responsabilidad del responsable o del encargado del tratamiento, habida cuenta de las medidas técnicas u organizativas que hayan aplicado en virtud de los artículos 25 y 32;
- e) toda infracción anterior cometida por el responsable o el encargado del tratamiento;
- f) el grado de cooperación con la autoridad de control con el fin de poner remedio a la infracción y mitigar los posibles efectos adversos de la infracción;
- g) las categorías de los datos de carácter personal afectados por la infracción;
- h) la forma en que la autoridad de control tuvo conocimiento de la infracción, en particular si el responsable o el encargado notificó la infracción y, en tal caso, en qué medida;
- i) cuando las medidas indicadas en el artículo 58, apartado 2, hayan sido ordenadas previamente contra el responsable o el encargado de que se trate en relación con el mismo asunto, el cumplimiento de dichas medidas;
- j) la adhesión a códigos de conducta en virtud del artículo 40 o a mecanismos de certificación aprobados con arreglo al artículo 42, y
- k) cualquier otro factor agravante o atenuante aplicable a las circunstancias del caso, como los beneficios financieros obtenidos o las pérdidas evitadas, directa o indirectamente, a través de la infracción”.

Por su parte, el artículo 76 “Sanciones y medidas correctivas” de la LOPDGDD dispone:

“1. Las sanciones previstas en los apartados 4, 5 y 6 del artículo 83 del Reglamento (UE) 2016/679 se aplicarán teniendo en cuenta los criterios de graduación establecidos en el apartado 2 del citado artículo.

2. De acuerdo a lo previsto en el artículo 83.2.k) del Reglamento (UE) 2016/679 también podrán tenerse en cuenta:

- a) El carácter continuado de la infracción.
- b) La vinculación de la actividad del infractor con la realización de tratamientos de datos personales.
- c) Los beneficios obtenidos como consecuencia de la comisión de la infracción.
- d) La posibilidad de que la conducta del afectado hubiera podido inducir a la comisión de la infracción.
- e) La existencia de un proceso de fusión por absorción posterior a la comisión de la infracción, que no puede imputarse a la entidad absorbente.
- f) La afectación a los derechos de los menores.
- g) Disponer, cuando no fuere obligatorio, de un delegado de protección de datos.
- h) El sometimiento por parte del responsable o encargado, con carácter voluntario, a mecanismos de resolución alternativa de conflictos, en aquellos

supuestos en los que existan controversias entre aquellos y cualquier interesado”.

En el presente caso, considerando la gravedad de la posible infracción, atendiendo especialmente a las consecuencias que su comisión provoca en los afectados, correspondería la imposición de multa, además de la adopción de medidas, si procede.

La multa que se imponga deberá ser, en cada caso individual, efectiva, proporcionada y disuasoria, conforme a lo establecido en el artículo 83.1 del RGPD. Para garantizar estos principios, se considera, con carácter previo, el volumen de negocio de IBERMUTUA (...) euros en el año 2023.

A efectos de decidir sobre la imposición de una multa administrativa y su cuantía, de conformidad con las evidencias de que se dispone en el presente momento de acuerdo de inicio de procedimiento sancionador, y sin perjuicio de lo que resulte de la instrucción, se considera que procede graduar la sanción a imponer de acuerdo con las circunstancias siguientes, contempladas en los preceptos antes citados.

Con carácter previo, se estima que concurren las circunstancias siguientes:

- La naturaleza, gravedad y duración de la infracción, teniendo en cuenta la naturaleza, alcance o propósito de la operación de tratamiento de que se trate, así como el número de interesados afectados y el nivel de los daños y perjuicios que hayan sufrido (artículo 83.2, letra a), del RGPD). En concreto, en el presente caso hay un número elevado de afectados, que se eleva a 3.395 personas.
- En cuanto a las categorías de los datos de carácter personal afectados por la infracción (artículo 83.2, letra g), del RGPD), cabe destacar que los envíos realizados incluían datos previstos en el artículo 9 del RGPD, como son datos de salud (relativos a bajas por enfermedad o por accidente). Asimismo, destaca la cantidad de datos enviados para cada uno de los afectados, lo cual es relevante, teniendo en cuenta que la vulneración del derecho a la privacidad y a la protección de los datos personales aumenta con la cantidad de datos.

El balance de las circunstancias contempladas en el artículo 83.2 del RGPD, con respecto a la infracción cometida al vulnerar lo establecido en el artículo 5.1.f) del RGPD, permite fijar inicialmente una sanción de multa administrativa de 1.000.000,00 euros.

VII

Medidas correctivas

De confirmarse la infracción, la resolución que se dicte podrá establecer las medidas correctivas que la entidad infractora deberá adoptar para poner fin al incumplimiento de la legislación de protección de datos personales, en este caso del Artículo 5.1.f) del RGPD, de acuerdo con lo establecido en el citado artículo 58.2.d) del RGPD, según el cual cada autoridad de control podrá *“ordenar al responsable o encargado del tratamiento que las operaciones de tratamiento se ajusten a las disposiciones del presente Reglamento, cuando proceda, de una determinada manera y dentro de un plazo especificado...”*

Así, se podrá requerir a la entidad responsable para que adecúe su actuación a la normativa de protección de datos personales, con el alcance expresado en los anteriores Fundamentos de Derecho.

En el presente acto se establece cuál es la presunta infracción cometida y los hechos que podrían dar lugar a esa posible vulneración de la normativa de protección de datos, de lo que se infiere con claridad cuáles son las medidas a adoptar, sin perjuicio de que el tipo de procedimientos, mecanismos o instrumentos concretos para implementarlas corresponda a la parte sancionada, pues es el responsable del tratamiento quien conoce plenamente su organización y ha de decidir, en base a la responsabilidad proactiva y en enfoque de riesgos, cómo cumplir con el RGPD y la LOPDGDD.

No obstante, en este caso, con independencia de lo anterior, de conformidad con las evidencias de que se dispone en el presente momento de acuerdo de inicio de procedimiento sancionador, en la resolución que se adopte se podrá requerir a IBERMUTUA para que, en el plazo de 3 meses, a contar desde la fecha de ejecutividad de la resolución finalizadora de este procedimiento, acreditar la aplicación de las medidas técnicas y organizativas adecuadas para prevenir brechas de seguridad en el envío de comunicaciones como las que son objeto de este procedimiento, como por ejemplo la limitación del número de archivos, incluir filtros o mecanismos que relacionen las personas cuyos datos son objeto de la comunicación con las entidades legitimadas para conocer sus datos o realizar pruebas previas a los envíos.

La imposición de estas medidas es compatible con la sanción consistente en multa administrativa, según lo dispuesto en el art. 83.2 del RGPD.

Se advierte que no atender la posible orden de adopción de medidas impuestas por este organismo en la resolución del presente procedimiento sancionador podrá ser considerado como una infracción administrativa conforme a lo dispuesto en el RGPD, tipificada como infracción en su artículo 83.5 y 83.6, pudiendo motivar tal conducta la apertura de un ulterior procedimiento administrativo sancionador.

Asimismo, se recuerda que ni el reconocimiento de la infracción cometida ni, en su caso, el pago voluntario de las cuantías propuestas, eximen de la obligación de adoptar las medidas pertinentes para que cese la conducta o se corrijan los efectos de la infracción cometida y la de acreditar ante esta AEPD el cumplimiento de esa obligación.

Por lo tanto, a tenor de lo anteriormente expuesto, por la Presidencia de la Agencia Española de Protección de Datos,

SE ACUERDA:

PRIMERO: INICIAR PROCEDIMIENTO SANCIONADOR a **IBERMUTUA MUTUA COLABORADORA CON LA SEGURIDAD SOCIAL Nº 274**, con NIF **G81939217**, por

la presunta infracción del artículo 5.1.f) del RGPD, tipificada en el artículo 83.5 del RGPD.

SEGUNDO: NOMBRAR como instructor a **R.R.R.** y, como secretaria, a **S.S.S.**, indicando que podrán ser recusados, en su caso, conforme a lo establecido en los artículos 23 y 24 de la Ley 40/2015, de 1 de octubre, de Régimen Jurídico del Sector Público (LRJSP).

TERCERO: INCORPORAR al expediente, a efectos probatorios, la reclamación interpuesta por la parte reclamante y su documentación, así como, así como los documentos obtenidos y generados por la Subdirección General de Inspección de Datos en las actuaciones previas al inicio del presente procedimiento sancionador.

CUARTO: QUE a los efectos previstos en el art. 64.2 b) de la ley 39/2015, de 1 de octubre, del Procedimiento Administrativo Común de las Administraciones Públicas, la sanción que pudiera corresponder sería de multa administrativa de 1.000.000,00 euros, sin perjuicio de lo que resulte de la instrucción.

QUINTO: NOTIFICAR el presente acuerdo a **IBERMUTUA MUTUA COLABORADORA CON LA SEGURIDAD SOCIAL Nº 274**, con NIF **G81939217**, otorgándole un plazo de audiencia de diez días hábiles para que formule las alegaciones y presente las pruebas que considere convenientes. En su escrito de alegaciones deberá facilitar su NIF y el número de procedimiento que figura en el encabezamiento de este documento.

De conformidad con lo dispuesto en el artículo 85 de la LPACAP, podrá reconocer su responsabilidad dentro del plazo otorgado para la formulación de alegaciones al presente acuerdo de inicio; lo que llevará aparejada una reducción de un 20% de la sanción que proceda imponer en el presente procedimiento. Con la aplicación de esta reducción, la sanción quedaría establecida en **800.000,00** euros, resolviéndose el procedimiento con la imposición de esta sanción.

Del mismo modo podrá, en cualquier momento anterior a la resolución del presente procedimiento, llevar a cabo el pago voluntario de la sanción propuesta, lo que supondrá la reducción de un 20% de su importe. Con la aplicación de esta reducción, la sanción quedaría establecida en **800.000,00** euros y su pago implicará la terminación del procedimiento, sin perjuicio de la imposición de las medidas correspondientes.

La reducción por el pago voluntario de la sanción es acumulable a la que corresponde aplicar por el reconocimiento de la responsabilidad, siempre que este reconocimiento de la responsabilidad se ponga de manifiesto dentro del plazo concedido para formular alegaciones a la apertura del procedimiento. El pago voluntario de la cantidad referida en el párrafo anterior podrá hacerse en cualquier momento anterior a la resolución. En este caso, si procediera aplicar ambas reducciones, el importe de la sanción quedaría establecido en **600.000,00 euros**.

En todo caso, la efectividad de cualquiera de las dos reducciones mencionadas estará condicionada al desistimiento o renuncia expresas de cualquier acción o recurso en vía administrativa contra la sanción.

A estos efectos, en caso de acogerse a alguna de ellas, deberá remitir a la Subdirección General de Inspección de datos comunicación expresa del desistimiento o renuncia a cualquier acción o recurso en vía administrativa contra la sanción indicando a cuál de las dos reducciones se acoge o si es a las dos.

En caso de que optara por proceder al pago voluntario de cualquiera de las cantidades señaladas anteriormente (**800.000,00 euros o 600.000,00 euros**), deberá hacerlo efectivo mediante su ingreso en la cuenta nº **IBAN: ES00-0000-0000-0000-0000 (BIC/Código SWIFT: CAIXESBBXXX)** abierta a nombre de la Agencia Española de Protección de Datos en la entidad bancaria CAIXABANK, S.A., indicando en el concepto el número de referencia del procedimiento que figura en el encabezamiento de este documento y la causa de reducción del importe a la que se acoge.

Asimismo, deberá enviar el justificante del ingreso a la Subdirección General de Inspección junto con la comunicación expresa del desistimiento o renuncia a cualquier acción o recurso en vía administrativa contra la sanción para continuar con el procedimiento en concordancia con la cantidad ingresada.

En cumplimiento de los artículos 14, 41 y 43 de la LPACAP, se advierte de que, en lo sucesivo, las notificaciones que se le remitan se realizarán exclusivamente de forma electrónica, a través de la Dirección Electrónica Habilitada única (dehu.redsara.es) y de la Sede electrónica (sedeagpd.gob.es), y que, de no acceder a ellas, se hará constar su rechazo en el expediente, dando por efectuado el trámite y siguiéndose el procedimiento. Se le informa que puede identificar ante esta Agencia una dirección de correo electrónico para recibir el aviso de puesta a disposición de las notificaciones y que la falta de práctica de este aviso no impedirá que la notificación sea considerada plenamente válida.

De conformidad con lo establecido en el artículo 76.4 de la LOPDGDD y si el importe de la sanción impuesta es superior a un millón de euros, será objeto de publicación en el Boletín Oficial del Estado la información que identifique al infractor, la infracción cometida y el importe de la sanción impuesta.

Por último, se señala que conforme a lo establecido en el artículo 112.1 de la LPACAP, contra el presente acto no cabe recurso administrativo alguno.

1479-111224

Olga Pérez Sanjuán

La Subdirectora General de Inspección de Datos, de conformidad con el art. 48.2 LOPDGDD, por vacancia del cargo de Presidencia y Adjunta

>>

SEGUNDO: En fecha 17 de febrero de 2025, **IBERMUTUA** ha procedido al pago de la sanción en la cuantía de **600.000,00 euros** haciendo uso de las dos reducciones previstas en el acuerdo de inicio transcrito anteriormente, lo que implica el

reconocimiento de la responsabilidad en relación con los hechos a los que se refiere el acuerdo de inicio y su calificación jurídica.

TERCERO: IBERMUTUA ha renunciado expresamente a cualquier acción o recurso en vía administrativa contra la sanción.

CUARTO: En el acuerdo de inicio transcrito anteriormente se señalaba que, de confirmarse la infracción, podría acordarse imponer al responsable la adopción de medidas adecuadas para ajustar su actuación a la normativa mencionada en este acto, de acuerdo con lo establecido en el citado artículo 58.2 d) del RGPD, según el cual cada autoridad de control podrá “ordenar al responsable o encargado del tratamiento que las operaciones de tratamiento se ajusten a las disposiciones del presente Reglamento, cuando proceda, de una determinada manera y dentro de un plazo especificado...”.

Habiéndose reconocido la responsabilidad de la infracción, procede la imposición de las medidas incluidas en el acuerdo de inicio.

FUNDAMENTOS DE DERECHO

I

Competencia

De acuerdo con los poderes que el artículo 58.2 del Reglamento (UE) 2016/679 (Reglamento General de Protección de Datos, en adelante RGPD), otorga a cada autoridad de control y según lo establecido en los artículos 47, 48.1, 64.2 y 68.1 de la Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y garantía de los derechos digitales (en adelante, LOPDGDD), es competente para resolver este procedimiento la Presidencia de la Agencia Española de Protección de Datos.

Asimismo, el artículo 63.2 de la LOPDGDD determina que: *"Los procedimientos tramitados por la Agencia Española de Protección de Datos se registrarán por lo dispuesto en el Reglamento (UE) 2016/679, en la presente ley orgánica, por las disposiciones reglamentarias dictadas en su desarrollo y, en cuanto no las contradigan, con carácter subsidiario, por las normas generales sobre los procedimientos administrativos."*

II

Terminación del procedimiento

El artículo 85 de la Ley 39/2015, de 1 de octubre, del Procedimiento Administrativo Común de las Administraciones Públicas (en lo sucesivo, LPACAP), bajo la rúbrica *"Terminación en los procedimientos sancionadores"* dispone lo siguiente:

"1. Iniciado un procedimiento sancionador, si el infractor reconoce su responsabilidad, se podrá resolver el procedimiento con la imposición de la sanción que proceda.

2. Cuando la sanción tenga únicamente carácter pecuniario o bien quepa imponer una sanción pecuniaria y otra de carácter no pecuniario pero se ha justificado la

improcedencia de la segunda, el pago voluntario por el presunto responsable, en cualquier momento anterior a la resolución, implicará la terminación del procedimiento, salvo en lo relativo a la reposición de la situación alterada o a la determinación de la indemnización por los daños y perjuicios causados por la comisión de la infracción.

3. En ambos casos, cuando la sanción tenga únicamente carácter pecuniario, el órgano competente para resolver el procedimiento aplicará reducciones de, al menos, el 20 % sobre el importe de la sanción propuesta, siendo éstos acumulables entre sí. Las citadas reducciones, deberán estar determinadas en la notificación de iniciación del procedimiento y su efectividad estará condicionada al desistimiento o renuncia de cualquier acción o recurso en vía administrativa contra la sanción.

El porcentaje de reducción previsto en este apartado podrá ser incrementado reglamentariamente.”

III

Pago voluntario y reconocimiento de responsabilidad

De conformidad con lo dispuesto en el citado artículo 85 de la LPACAP, en el acuerdo de inicio notificado se informaba sobre la posibilidad de reconocer la responsabilidad y de realizar el pago voluntario de la sanción propuesta, lo que supondría dos reducciones acumulables de un 20% cada una. Con la aplicación de estas dos reducciones, la sanción quedaría establecida en **600.000,00 euros** y su pago implicaría la terminación del procedimiento, sin perjuicio de la imposición de las medidas correspondientes.

Tras la notificación del citado acuerdo de inicio, **IBERMUTUA** ha procedido al reconocimiento de la responsabilidad y al pago voluntario de la sanción, acogándose a las dos reducciones previstas y renunciando expresamente a cualquier acción o recurso en vía administrativa.

Debe tenerse en cuenta que, de acuerdo con los preceptos de la LPACAP, así como de la jurisprudencia del Tribunal Supremo en esta materia, el ejercicio del pago voluntario por el presunto responsable no exime a la administración de la obligación de resolver y notificar todos los procedimientos, cualquiera que sea su forma de iniciación. De igual forma, el artículo 88 de la citada norma establece que la resolución que ponga fin al procedimiento decidirá todas las cuestiones planteadas por los interesados y aquellas otras derivadas del mismo.

Por lo tanto, de acuerdo con la legislación aplicable y valorados los criterios de graduación de las sanciones cuya existencia ha quedado acreditada, la Presidencia de la Agencia Española de Protección de Datos **RESUELVE:**

PRIMERO: DECLARAR la comisión de las infracciones y CONFIRMAR las sanciones determinadas en la parte dispositiva del acuerdo de inicio transcrito en la presente resolución.

La suma de las citadas cuantías arroja una cantidad total **1.000.000,00 euros**.

Tras haber procedido **IBERMUTUA, MUTUA COLABORADORA CON LA SEGURIDAD SOCIAL NUM.274** al pronto pago y reconocimiento de responsabilidad, se procede, en virtud del artículo 85 de la LPACAP, a la reducción de un 40% del total mencionado, lo cual supone la cantidad definitiva de **600.000,00 euros**.

SEGUNDO: DECLARAR la terminación del procedimiento **EXP202412881**, de conformidad con lo establecido en el artículo 85 de la LPACAP.

TERCERO: ORDENAR a **IBERMUTUA, MUTUA COLABORADORA CON LA SEGURIDAD SOCIAL NUM.274** para que en el plazo de 3 meses desde que la presente resolución sea firme y ejecutiva, notifique a la Agencia la adopción de las medidas que se describen en los fundamentos de derecho del acuerdo de inicio transcrito en la presente resolución.

CUARTO: NOTIFICAR la presente resolución a **IBERMUTUA, MUTUA COLABORADORA CON LA SEGURIDAD SOCIAL NUM.274**.

QUINTO: De acuerdo con lo previsto en el artículo 85 de la LPACAP que condiciona la reducción por pago voluntario y reconocimiento de la responsabilidad al desistimiento o renuncia de cualquier acción o recurso en vía administrativa, por parte de la presente autoridad se acepta la renuncia expresamente manifestada por **IBERMUTUA, MUTUA COLABORADORA CON LA SEGURIDAD SOCIAL NUM.274**, no cabiendo en consecuencia la interposición de recurso potestativo de reposición frente a la presente resolución, todo ello sin perjuicio de la posibilidad de acudir a la vía jurisdiccional contencioso-administrativa.

En consecuencia, teniendo en cuenta lo dispuesto en el artículo 90 de la LPACAP, dado que no cabe ningún recurso en vía administrativa al haber renunciado expresamente, la presente resolución será firme y plenamente ejecutiva a partir de su notificación.

No obstante, conforme a lo previsto en el artículo 90.3.a) de la LPACAP, se podrá suspender cautelarmente la resolución firme en vía administrativa si el interesado manifiesta su intención de interponer recurso contencioso-administrativo. De ser éste el caso, el interesado deberá comunicar formalmente este hecho mediante escrito dirigido a la Agencia Española de Protección de Datos, presentándolo a través del Registro Electrónico de la Agencia [<https://sedeagpd.gob.es/sede-electronica-web/>], o a través de alguno de los restantes registros previstos en el art. 16.4 de la citada Ley 39/2015, de 1 de octubre. También deberá trasladar a la Agencia la documentación que acredite la interposición efectiva del recurso contencioso-administrativo. Si la Agencia no tuviese conocimiento de la interposición del recurso contencioso-administrativo en el plazo de dos meses desde el día siguiente a la notificación de la presente resolución, daría por finalizada la suspensión cautelar.

De conformidad con lo establecido en el artículo 50 de la LOPDGDD, la presente Resolución se hará pública una vez haya sido notificada a los interesados.

1259-180225

Olga Pérez Sanjuán

La Subdirectora General de Inspección de Datos, de conformidad con el art. 48.2 LOPDGDD, por vacancia del cargo de Presidencia y Adjuntía